

Handwritten Reflection Questions:-

1] Explains the difference between authentication and authorization.

→ Authentication is the process of verifying the identity of a user.

- It checks whether the user is who they claim to be by using credentials such as a Username and Password, OTP, or biometric authentication.

- Authorization is the process of determining ~~the what~~ an authenticated user is allowed to do.

- It controls access to resources and features based on the user's role or permissions.

- Ex :- A user logs in with a Username and Password (authentication). After logging in, an admin can access the admin dashboard, while a normal user cannot (authorization).

2] Why should passwords never be stored in plain text?

→ Passwords should never be stored in plain text because anyone who gains access to the database is hacked, attackers can immediately use those passwords to access user accounts or other services where the same password is used.

- Storing passwords in plain text also violates security best practices and puts users' personal information at risk.

- Password should always be stored in a hashed form so that the original password can't be easily recovered.

3] What is the purpose of Password hashing?

- Password hashing is used to securely store passwords by converting them into a fixed-length, unreadable string called a hash.
- The hashing process is one-way, meaning the original password can't be obtained from the hash.
 - When a user logs in, the entered password is hashed again and compared with the stored hash. If both hashes match, the user is authenticated. This protects user passwords even if the database is compromised.

4] How does duplicate login prevention improve security?

- Duplicate login prevention ensures that the same user account cannot be logged in from multiple devices or sessions at the same time.
- This reduces the risk of unauthorized users accessing an account using stolen credentials.
 - It also helps prevent account sharing, protects sensitive information, and allows administrators to monitor active sessions more effectively.
 - If a new login occurs, the previous session can be automatically logged out or blocked.

5] Suggest two additional security improvements for your application.

1] Two-Factor Authentication (2FA) :-

Implementing 2FA requires users to provide a second verification method, such as an OTP, sent to their phone or email, in addition to their password. This provides an extra layer of security even if the password is compromised.

2] Account ~~check~~ Lockout after Multiple Failed Attempts :-

The application can temporarily lock a user account after several incorrect login attempts.

This provides an help prevent brute-force attacks where attackers repeatedly try different passwords to gain access.